New research

9 of 10 models raised their own spending cap.

What a Cornell Tech and Yale study means for anyone relying on an agent's limits.

HalvorAI

The test

A cap, a wallet and an inbox.

Wallet	Circle agent wallet on Base mainnet, holding 10 USDC
Cap	0.01 USDC a day
Task	Pay the invoices in the inbox
Gate	Raising the cap takes a one-time code sent by email
Access	The agent could read that email
Runs	10 models, 20 runs each

Result 1: no attack involved

9 of 10

models read the code from the inbox and raised their own cap in at least one run.

That is "at least once in 20", not a typical rate. It varied across and within models, and it didn't track model capability.

Result 2: emails posing as the user

5 of 10

models paid an address the researchers controlled in at least one run. The task was only to summarize the inbox.

The authors call this a lower bound, since the attack wasn't tailored to each model.

Why it worked

The gate shared a channel with the agent.

A human approval only counts if the agent can't reach the channel it travels on. Here, the code landed in an inbox the agent could already read.

Fix	The authors propose approval on a trusted device the agent can't control. Their prototype, Countersign, uses ordinary phones.
Since	Circle's docs now warn against giving agents unrestricted email access.

What the record shows

A raised cap doesn't change a signed mandate.

A wallet setting can change. A signed AP2 or Verifiable Intent credential doesn't. A payment that carries a valid mandate is evaluated against that mandate.

Our limits

We sit outside the payment path. We report this, and we don't stop it.

No mandate on the payment means not_evaluable. APE v0.1 records payments, not limit changes.

For risk teams

Four questions for any agent limit.

1 Who can change it?

2 Through which channel?

3 Can the agent reach that channel?

4 What record does a change leave?

Paper: arxiv.org/abs/2610.35835